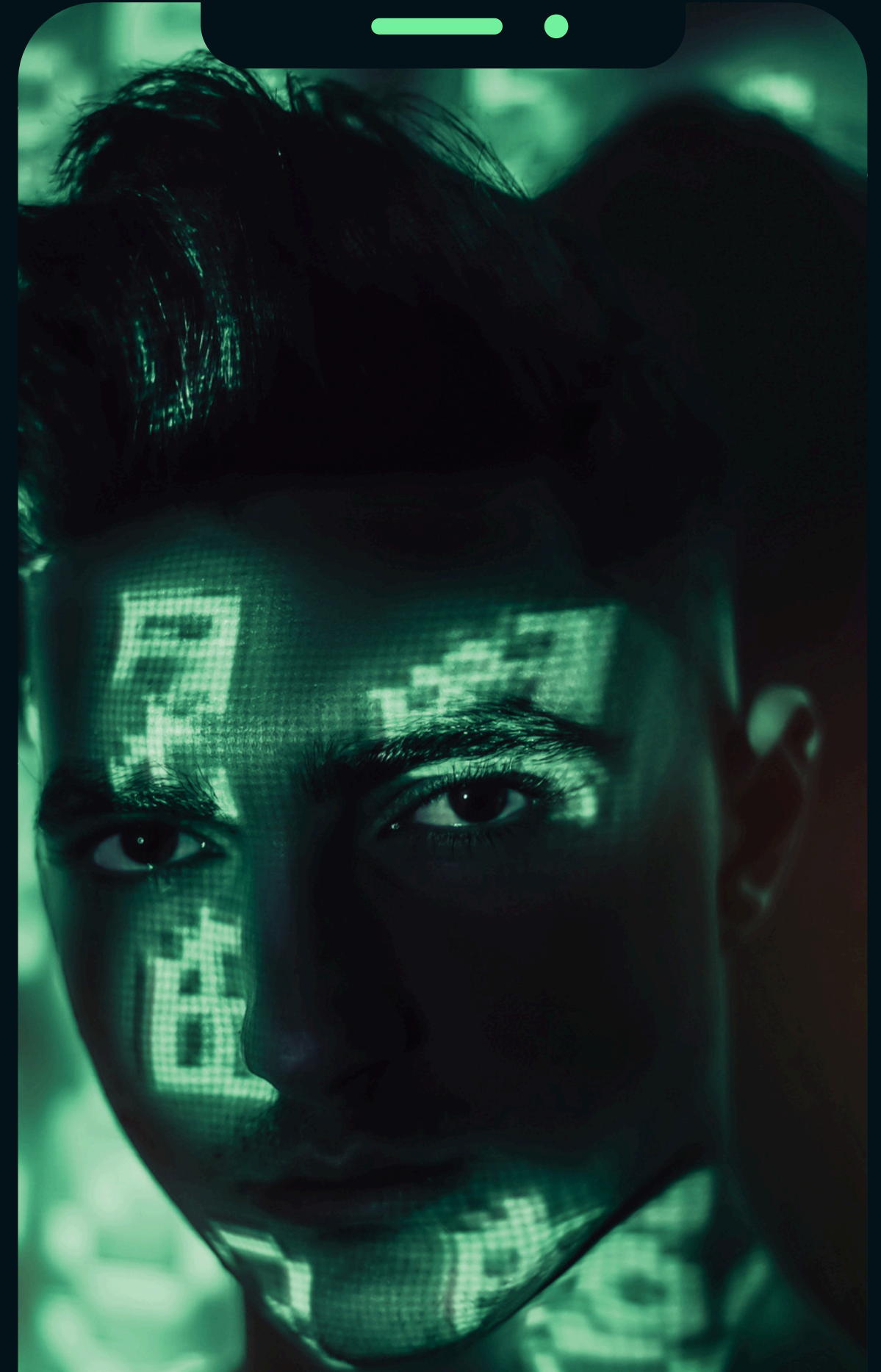


Red Teaming (PWN)

@OlsonTyler0



Topics

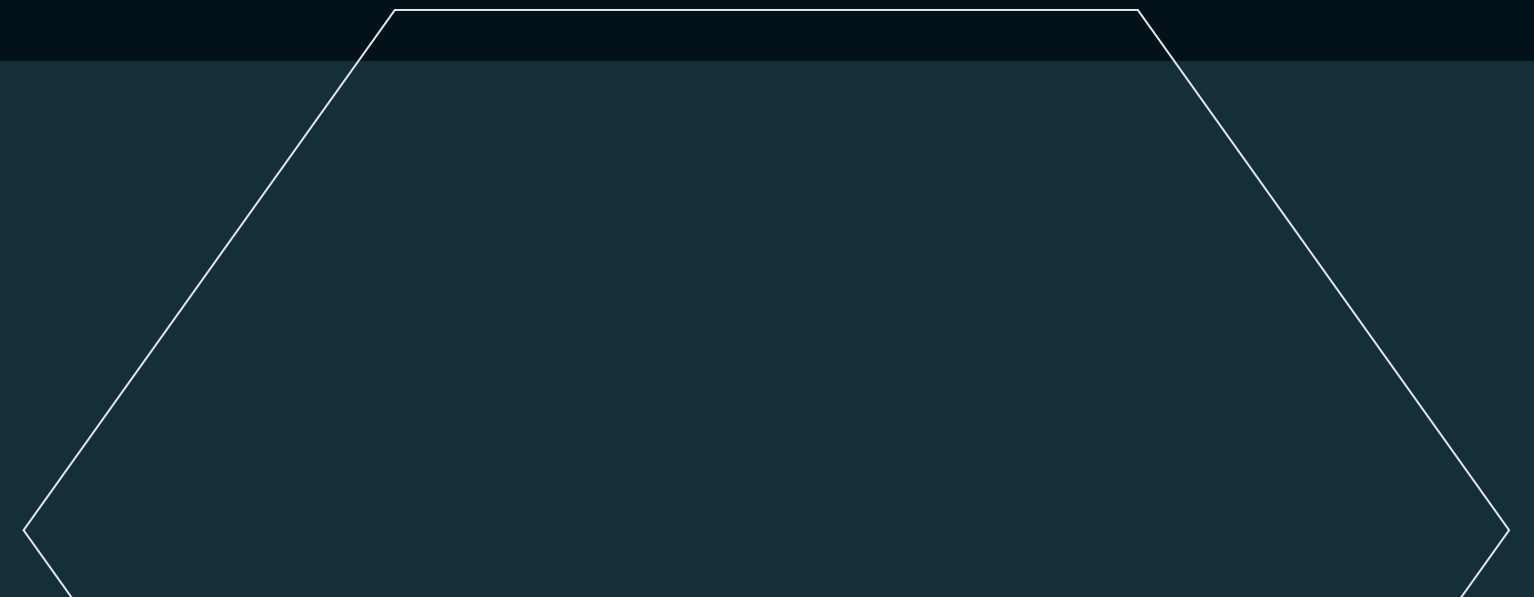
Welcome to the Digital Frontier

What is Ethical Hacking? What are ethical hackers responsible for?

How do we hack ethically? What do we target?

First stage: Reconnaissance

LAB: Starting a Kali VM and a Target VM
LAB Recon a target



What is Ethical Hacking?



“Hacking with approval”

- Very writing heavy, Reports take time
 - Can be long 20+ pages for a single report.
 - Intended to be non-technical in nature
- **Other responsibilities of a pentester**
 - Working with teams post engagement for improved protections
 - Continued education (testing environments and paid for education)

[Example Pentest Report](#)

Types of security controls

- **Preventative** - Antivirus, updates
- **Deterrent** - Legal notices, security guard
- **Detective** - SIEM, IDS, EDR
- **Corrective** - Backups, Passwords
- **Compensating** - (Cover where the others can't) - Pentesting, Training

Why does this matter?

- The objective of engagement is to cover what others cannot and is a key part of controls
- Pentesting is being proactive
- Blue teaming is being reactive

Reactive vs Proactive Controls

Advantages to different testing methodologies

External

“One-time engagement from an outside source”

Adv:

- Tester is not biased to the internal company
- Larger amount of pentesting resources
- Can be a more specialized engagement

Internal

“An individual with the title of pen tester in the company”

- Tester can be biased to company practices
- Testing would be continual and can work with development

Black-Box

“Attacker is completely blind to the customer environment and has to gather information”

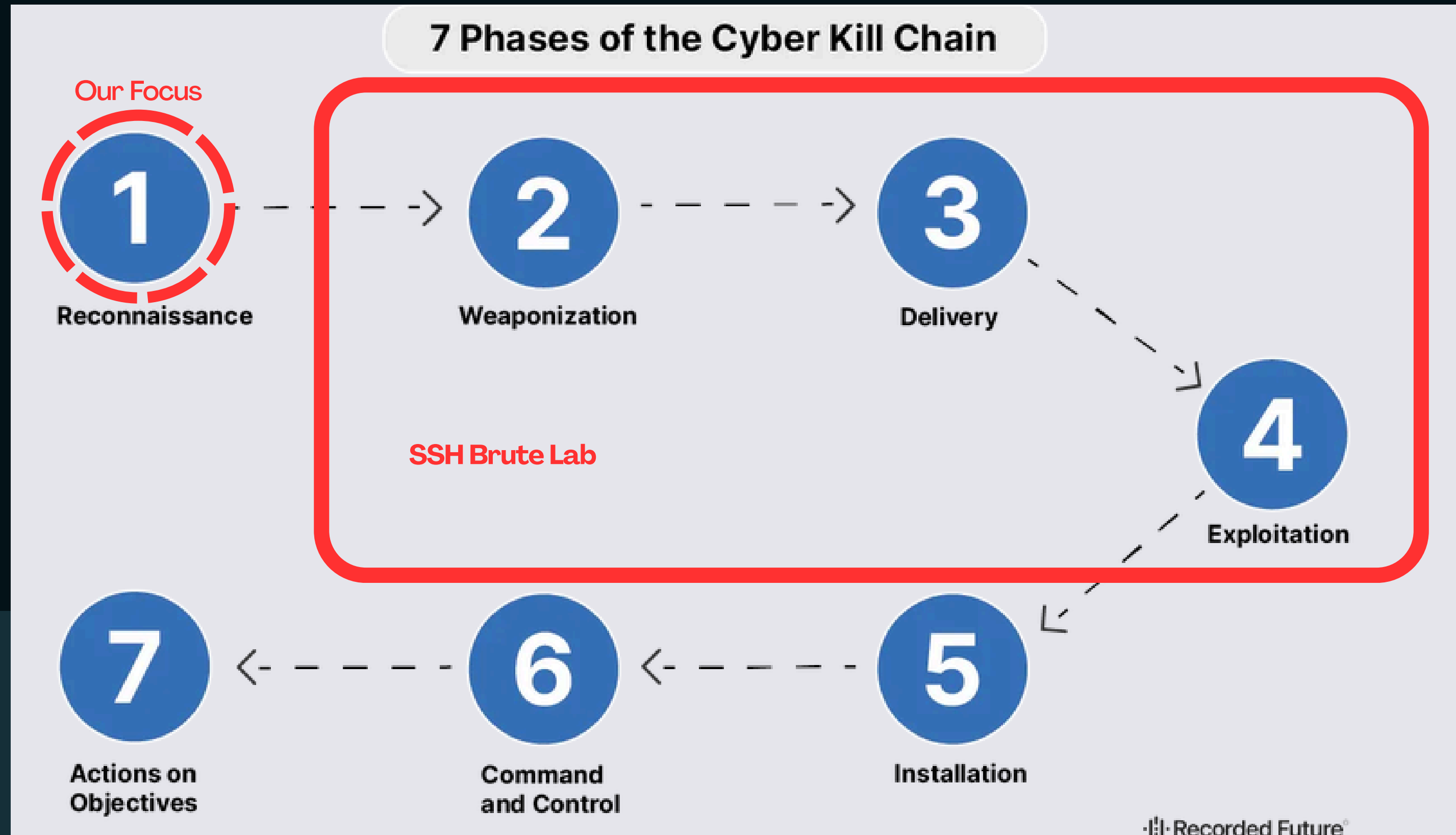
- Can see directly from the attacker experience
- Find potential recon weakpoints (exposed emails, etc)
- Most directly emulates an external attacker

White-Box

“Attacker has complete knowledge of the target network, possibly including valid credentials”

- Quick and expedited testing
- Ensures comprehensive coverage
- Assumes compromise

How: Cyber Kill Chain



Mitre Att&ck

- Generally describes attack vectors
- Important to know when writing reports to provide reference points
- Other Mitre resources will help in engagements

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (5)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (13)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	BITS Jobs	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Exfiltration Over C2 Channel	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Exploitation for Client Execution	Compromise Host Software Binary	Create or Modify System Process (5)	Delay Execution	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Obtain Capabilities (7)	Replication Through Removable Media	Input Injection	Create Account (3)	Domain or Tenant Policy Modification (2)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Web Service (4)	Email Bombing
Search Open Technical Databases (5)	Stage Capabilities (6)	Supply Chain Compromise (3)	Inter-Process Communication (3)	Create or Modify System Process (5)	Event Triggered Execution (18)	Direct Volume Access	Modify Authentication Process (9)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (2)	Fallback Channels	Scheduled Transfer	Endpoint Denial of Service (4)
Search Open Websites/ Domains (3)	Trusted Relationship	Valid Accounts (4)	Native API	Event Triggered Execution (18)	Event Triggered Execution (18)	Domain or Tenant Policy Modification (2)	Multi-Factor Authentication Process (9)	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Information Repositories (6)	Hide Infrastructure	Transfer Data to Cloud Account	Financial Theft
Search Threat Vendor Data	Wi-Fi Networks	Scheduled Task/ Job (5)	Poisoned Pipeline Execution	Exclusive Control	Exploitation for Privilege Escalation	Email Spoofing	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Ingress Tool Transfer	Network Denial of Service (2)	Firmware Corruption
Search Victim-Owned Websites		Serverless Execution	Scheduled Task/ Job (5)	External Remote Services	Hijack Execution Flow (12)	Execution Guardrails (2)	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Multi-Stage Channels	Resource Hijacking (4)	Inhibit System Recovery
		Shared Modules	Implant Internal Image	Hijack Execution Flow (12)	Process Injection (12)	Exploitation for Defense Evasion	OS Credential Dumping (8)	File and Directory Permissions Modification (2)		Data from Removable Media	Non-Application Layer Protocol	Service Stop	System Shutdown/ Reboot
		Software Deployment Tools	Modify Authentication Process (9)	Scheduled Task/ Job (5)	Hijack Execution Flow (12)	File and Directory Permissions Modification (2)	Hide Artifacts (14)	Steal Application Access Token		Data Staged (2)	Proxy (4)		
		System Services (3)				Hide Artifacts (14)	Hijack Execution Flow (12)	Steal or Forge Authentication		Email Collection (3)	Remote Access Tools		
		User Execution (5)				Hijack Execution Flow (12)				Input Capture			

Common Tools

- Metasploit
 - Big exploit tool with lots of different modules and import points, popular to learn and use
- NMAP / Zenmap
 - Recon tool. You will use this a bit today.
- Thousands of tools, custom written, and not custom written
- Hashcat (Pass cracker)
- Burpsuite (Web Exploiter)
- Gobuster (Directory enumeration)

Applying this to CTF

PWN Category

“Owning the machine”

- Binary exploitation (little bit of Rev ENG OOS – youll need to do self study here it would take a semester to explain)
- CVE exploitation – Find the open port
- Other “hack this box comp” might quite literally have you take over a server (like HTB)

Web Category

Web exploitation, usually simple OWASP attacks, see owasp top 10.

- We will explore this next week w/ an entire attack chain from compromising a website → all stages of kill chain

LAB:

First stage: Recon

Topics we will avoid for time

- OSINT stage (what is the company, see our previous presentation on this topic)
- Skipping past targeting, and to a stage where we have a single target that is likely vulnerable

What you need

- Github: msu-abits
- Logged into the computer (on your own account)
- A virtual box instance ready

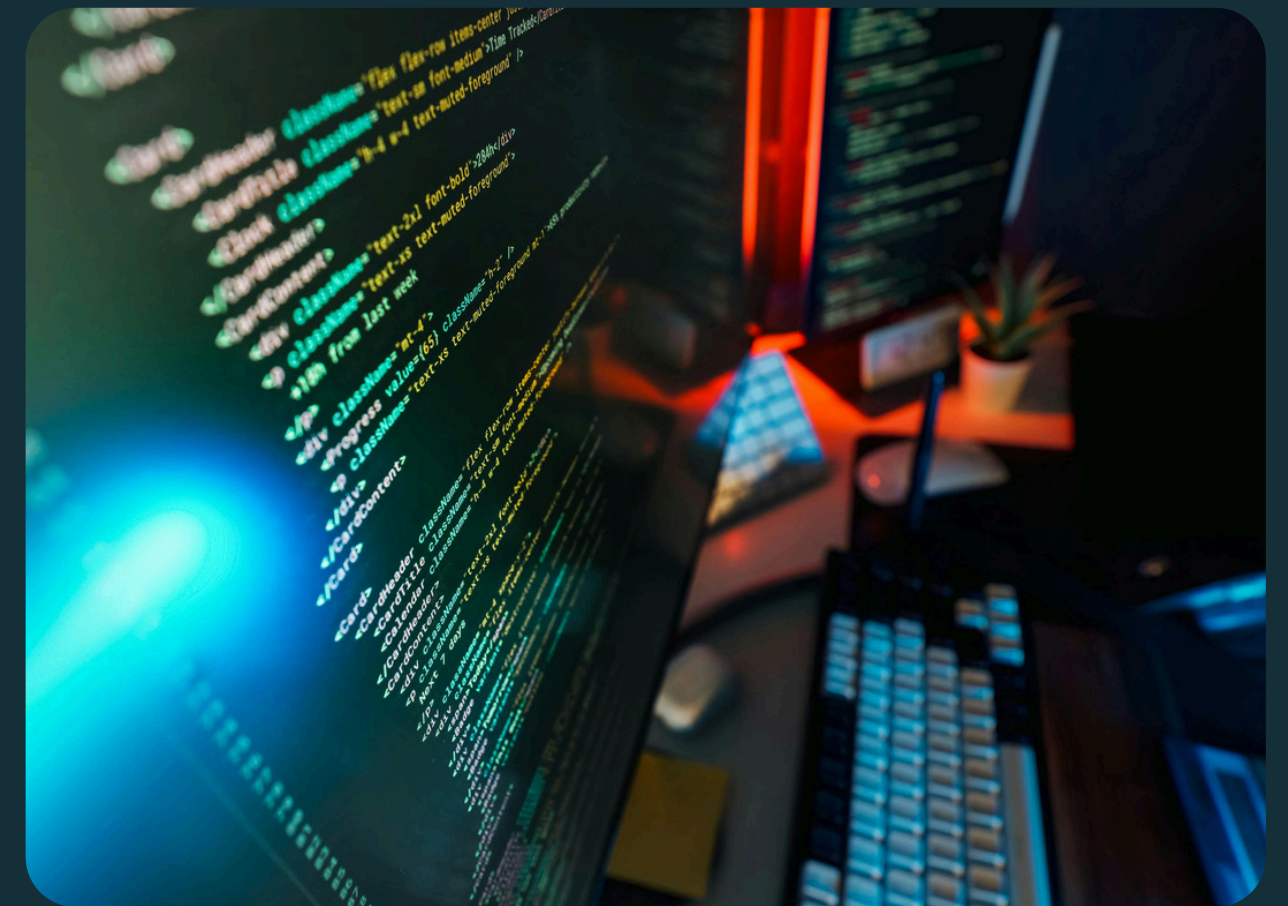
How this will work

We are going to do an entire engagement on machines prior to competition to get you comfortable with these topics.

Recon → Init Access → C2 → Action on Objectives

Instructions

1. Either download the image or use my provided USB drives to load both images onto your system.
2. Import the machines into virtual box
3. Follow Github lab guide



msu-abits/2025-cybersecurity



Repository for all information related to the 2025 cybersecurity project. including instruction guides, powerpoints, and required lab files.



Contributor



Issues



Stars



Forks



2025-cybersecurity/Week-7 Red-Teaming at main • msu-abits/2025-cybersecurity

Repository for all information related to the 2025 cybersecurity project. including instruction guides, powerpoints, and required lab files. - msu-abits/2025-cybersecurity



GitHub

Additional Learning

- Take a look at my new repo for additional learning,
- Practically dumped my entire youtube subscription list haha

msu-abits/**cyber-resource-list**



This was created to help anyone looking to learn cybersecurity and looking for recomendations on content / learning opprotunities

1

Contributor

0

Issues

0

Stars

0

Forks



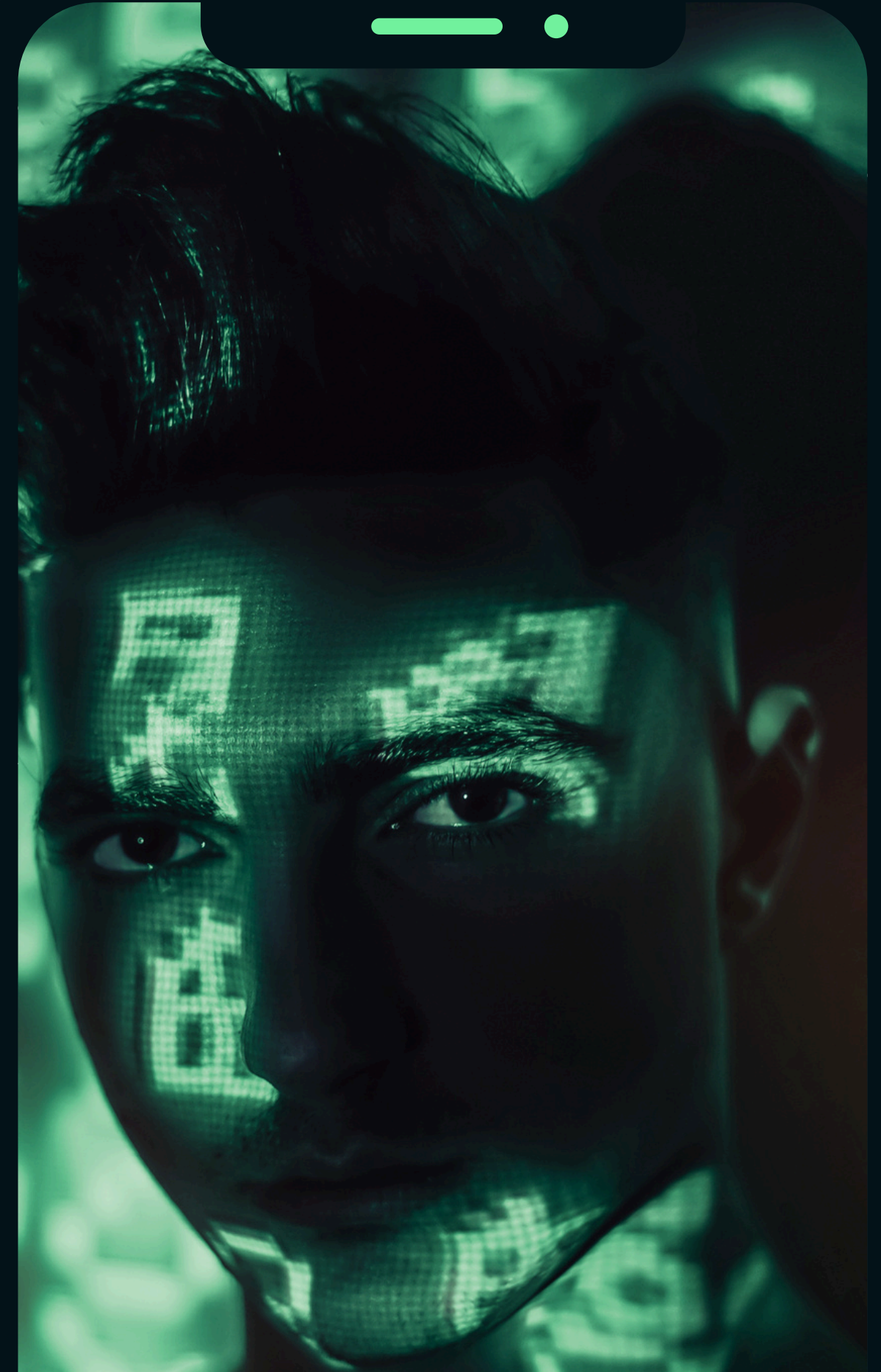
msu-abits/cyber-resource-list: This was created to help anyone looking to learn cybersecurity and looking for recomendations on content /...

This was created to help anyone looking to learn cybersecurity and looking for recomendations on content / learning opprotunities - msu-abits/cyber-resource-list

 GitHub

Personal Projects

@OlsonTyler0



Cyber Range

Requirements

- Computer or server that can host several VMs
- Kali VM image
- Windows 11 image
- Windows server image (See azure student for free image)
- Ubuntu 24.04 desktop image

Objectives

- Create a range of servers that can be used to test new technology or broken and refreshed as much as needed

Steps

Install all VMs onto a VM area

- Research how to network these VMs isolated from your host machine
- Find a technology you wish to investigate (splunk, wazuh, etc) install it in a new VM
- Install the agents or tech into the machines you have and go wild!

Homelab

My Adiver

- Find yourself a second small computer if possible, use as a server and install proxmox to easily put VMs
- Use tools like the proxmox VE scripts (OR LEARN YOURSELF) in how to put VMs and images on there. The longer you use it the better off you will be
- Find use cases off of youtube, like inventory management, DNS, etc.

Objectives

- Learn about server management and maintenance

Steps

Obtain a second computer
Install proxmox
Install any VMs you wish. I recommend looking at Proxmox VE Scripts to help you find new content to add. Modify and mess around with the servers and write about your experience

Learning DNS – Adguard

Requirements

- Computer that can either host a vm
- An Iso image from [ubuntu server](#)

Objectives

- Research DNS and how it functions. learn how it can be used to block advertisements

Steps

- Setup Adguard Home on an ubuntu 24.04 server.
- Set your main computer's DNS server to the adguard home server
- Investigate the DNS requests your computer makes without any interaction
- Use blocklists and test their function

Thanks

